

Capítulo 7

Varreduras ativas, passivas e furtivas de rede

7.1. Objetivos

- Mapear hosts ativos na rede
- Obter versões dos sistemas operacionais
- Entender aquisição de banners
- Identificar os serviços em execução

7.2. Varreduras Internet Control Messages Protocol (ICMP)

O protocolo IP (Internet Protocol) é conhecido como "protocolo do melhor esforço", devido a sua característica de sempre procurar o melhor caminho até uma determinada rede ou host. O IP possui um fiel escudeiro, um chamado ICMP (Internet Control Messages Protocol) e, de acordo com a RFC792 o ICMP é empregado quando:

- Quando um pacote não consegue chegar ao destino
- Quando um roteador não consegue encaminhar um pacote
- Quando um roteador descobre uma rota mais curta para um destino

Ferramentas como o ping e o traceroute utilizam o protocolo de controle ICMP para determinar se um host está vivo na rede e para mapear os roteadores até um destino, por exemplo.

O 'ping' é um ICMP echo request (tipo 8) e o 'pong' é um ICMP echo reply (tipo 0). Há uma infinidade de icmp types, que podem ser consultados no site da iana.

Sabendo dessa particularidade, podemos utilizar uma ferramenta simples chamada fping, que pode facilmente detectar todos os hosts ativos numa rede, desde que os mesmos respondam icmp.



```
#fping -c1 -g 192.168.200.0/24 2> /dev/null > /tmp/ips.txt
```

O nmap também pode ser usado com a opção -sP



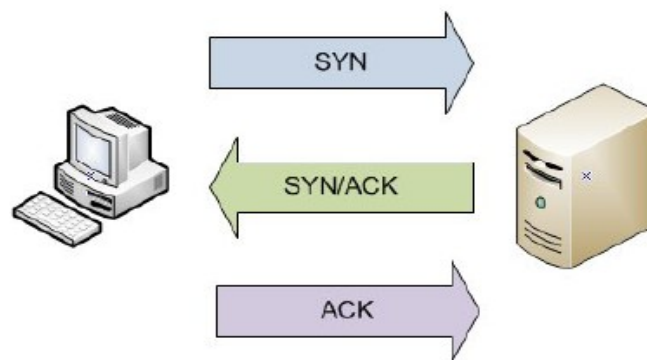
```
#nmap -sP 192.168.200.0/24
```

No caso do nmap, se utilizarmos a opção Ping Scan (-sP), observamos que mesmo se uma máquina estiver bloqueando pacotes ICMP, ele poderá listá-la como ativa, pois ele também envia pacotes TCP para algumas portas, como por exemplo a porta 80.

Assim, conseguimos a lista de todos os computadores que respondem ping na rede.

7.3. Varreduras TCP

Enquanto que as varreduras ICMP nos informam a quantidade de hosts ativos em uma rede, as varreduras TCP nos informam o número de portas abertas em um determinado computador. Para descobrir se uma porta esta aberta ou fechada, o programa chamado port scanner manipula uma característica do protocolo TCP, chamada Three Way Handshake, descrita na RFC 793.



De acordo com a imagem, o cliente, que deseja conectar-se a um servidor, envia um pedido de conexão, ou seja, no cabeçalho do datagrama TCP contém uma flag do tipo "SYN".

O servidor, que está apto a atender novas requisições responde então com um datagrama TCP contendo uma flag do tipo "SYN" + "ACK".

O cliente então responde com um datagrama contendo um "ACK", e então é estabelecida a conexão.

De acordo com a RFC 793, que define os parâmetros para o protocolo TCP, toda porta aberta deve responder com a flag "SYN+ACK", e toda porta fechada deve responder com uma flag "RST".

Para identificar este comportamento, vamos utilizar a ferramenta linha de comando hping3.

Verificando o comportamento de um servidor com a porta 80 aberta.

```
# hping3 --syn -c 1 -p 80 192.168.0.173
HPING 192.168.0.173 (eth0 192.168.0.173): S set, 40 headers + 0 data bytes
len=46 ip=192.168.0.173 ttl=128 DF id=1067 sport=80 flags=SA seq=0 win=64240
rtt=4.3 ms
```

O mesmo comando agora em uma porta fechada.

```
# hping3 --syn -c 1 -p 81 192.168.0.173
HPING 192.168.0.173 (eth0 192.168.0.173): S set, 40 headers + 0 data bytes
len=46 ip=192.168.0.173 ttl=128 id=1069 sport=81 flags=RA seq=0 win=0 rtt=1.0 ms
```

Perceba que as respostas são, SA, que representa um "SYN + ACK", e um RA, que representa um "Reset + ACK", a resposta padrão para portas fechadas.

7.4. Nmap

Nmap pode ser considerada uma das ferramentas mais completas para realizar varreduras em redes, pois possui um número imenso de opções, permitindo explorarmos quase todas as possibilidades de varreduras possíveis.

Essa ferramenta possui, inclusive, opções que permitem burlar sistemas de proteção, como IDS/IPS e Firewall, cujas regras poderiam bloquear ou detectar varreduras não permitidas.

Sintaxe: nmap [Scan Type(s)] [Options] {target specification}

7.5. Métodos de Varredura

7.5.1. -sP

Ping scan: Algumas vezes é necessário saber se um determinado host ou rede está no ar. Nmap pode enviar pacotes ICMP "echo request" para verificar se determinado host ou rede está ativa. Hoje em dia, existem muitos filtros que rejeitam os pacotes ICMP "echo request", então envia um pacote TCP ACK para a porta 80

(default) e caso receba RST o alvo está ativo. A terceira técnica envia um pacote SYN e espera um RST ou SYN-ACK.

7.5.2. -sV

Version detection: Após as portas TCP e/ou UDP serem descobertas por algum dos métodos, o nmap irá determinar qual o serviço está rodando atualmente. O arquivo nmap-service-probes é utilizado para determinar tipos de protocolos, nome da aplicação, número da versão e outros detalhes.

7.5.3. -sS

TCP SYN scan: Técnica também conhecida como “half-open”, pois não abre uma conexão TCP completa. É enviado um pacote SYN, como se ele fosse uma conexão real e aguarda uma resposta. Caso um pacote SYN-ACK seja recebido, a porta está aberta, enquanto que um RST-ACK como resposta indica que a porta está fechada. A vantagem dessa abordagem é que poucos irão detectar esse scanning de portas.

7.5.4. -sT

TCP connect() scan: É a técnica mais básica de TCP scanning. É utilizada a chamada de sistema (system call) “connect()” que envia um sinal as portas ativas. Caso a porta esteja aberta recebe como resposta “connect()”. É um dos scan mais rápidos, porém fácil de ser detectado.

7.5.5. -sU

UDP scan: Este método é utilizado para determinar qual porta UDP está aberta em um host. A técnica consiste em enviar um pacote UDP de 0 byte para cada porta do host. Se for recebida uma mensagem ICMP “port unreachable” então a porta está fechada, senão a porta pode estar aberta. Para variar um pouco, a

Microsoft ignorou a sugestão da RFC e com isso a varredura de máquinas Windows é muito rápida.

7.5.6. -sF, -sX, -sN

Stealth FIN, Xmas Tree ou Null: Alguns firewalls e filtros de pacotes detectam pacotes SYN's em portas restritas, então é necessário utilizar métodos avançados para atravessar esses softwares.

FIN: Portas fechadas enviam um pacote RST como resposta a pacotes FIN, enquanto portas abertas ignoram esses pacotes. (Esse método não funciona com a plataforma Windows, uma vez que a Microsoft não seguiu RFC 973)

Xmas Tree: Portas fechadas enviam um pacote RST como resposta a pacotes FIN, enquanto portas abertas ignoram esses pacotes. As flags FIN, URG e PUSH são utilizados nos pacotes FIN que é enviado ao alvo. (Esse método não funciona com a plataforma Windows, uma vez que a Microsoft não seguiu RFC 973)

Null: Portas fechadas enviam um pacote RST como resposta a pacotes FIN, enquanto portas abertas ignoram esses pacotes. Nenhuma flag é ligada no pacote FIN. (Esse método não funciona com a plataforma Windows, uma vez que a Microsoft não seguiu RFC 973)

7.5.7. -T <Paranoid|Sneaky|Polite|Normal|Aggressive|Insane>

Esse parâmetro seta a prioridade de varredura do Nmap:

- **Paranoid (-T0)** é muito lento na esperança de prevenir a detecção pelo sistema IDS. Este serializa todos os scans (scanning não paralelo) e geralmente espera no mínimo 5 minutos entre o envio de pacotes.
- **Sneaky (-T1)** é similar ao Paranoid, exceto que somente espera 15 segundos entre o envio de pacotes.
- **Polite (-T2)** tem o significado para facilitar a carga na rede e reduzir as chances de travar a máquina. Ele serializa os testes e espera no mínimo

0.4 segundos entre eles.

- **Normal (-T3)** é o comportamento default do Nmap, o qual tenta executar tão rápido quanto possível sem sobrecarregar a rede ou perder hosts/portas.
- **Aggressive(-T4)** esse modo adiciona um timeout de 5 minutos por host e nunca espera mais que 1.25 segundos para testar as respostas.
- **Insane (-T5)** é somente adequando para redes muito rápidas ou onde você não se importa em perder algumas informações. Nesta opção o timeout dos hosts acontece em 75 segundos e espera somente 0.3 segundos por teste individual.



Opções Interessantes:

-p → Utilizado para especificar portas

-O → Mostra a versão do S.O

-P0 → Desativa ICMP tipo 8 e o TCP ACK na porta 80

7.6. Prática dirigida

7.6.1. Mapeando portas abertas em um servidor



```
#nmap -sT 192.168.0.173
```

Esta varredura é o comportamento padrão do Nmap que é utilizado quando não temos privilégios de root ou em redes Ipv6. Nesta varredura, o Nmap utiliza uma chamada de sistema do tipo "connect()", e seu desempenho depende fortemente da implementação da pilha TCP/IP feita no sistema operacional.

Os resultados possíveis para esta varredura são:

- Open/Filtered: Aberta e aceitando conexões e/ou filtrada por firewall
- Closed/Filtered: Porta fechada e/ou filtrada por firewall

Varreduras baseadas em fim de conexão:



```
#nmap -sF 192.168.0.173
```

Esta varredura explora o comportamento padrão da RFC 792. De acordo com ela, um pacote marcado com a flag "FIN" deve causar como resposta um pacote com a flag "RST" para portas que estejam fechadas, e devem ser descartados se a porta estiver aberta.

Devido a esta característica, os resultados serão:

- Open/Filtered: Aberta e/ou filtrada por firewall
- Closed/Filtered: Fechada e/ou filtrada por firewall

Varredura Nula:



```
#nmap -sN 192.168.0.173
```

Alguns sistemas operacionais que não seguem a RFC estritamente podem dar respostas diferentes do esperado. Sabendo deste comportamento, podemos enviar um pacote sem nenhum conteúdo e então observar a resposta do alvo.

As respostas podem variar de sistema operacional para sistema operacional, mas geralmente recebemos:

- Open/Filtered: Aberta e/ou filtrada por firewall
- Closed: Fechada

Varredura para identificação de firewalls:



```
#nmap -sA 192.168.0.173
```

O objetivo desta varredura é mapear as regras de um firewall para determinar se o mesmo faz tratamento completo de conexão ou não.

Os únicos resultados neste tipo de varredura são:

- Filtered: A porta está protegida por firewall
- Unfiltered: A porta não está protegida por firewall

7.7. Tunelamento

O tunelamento, basicamente, é a técnica de encapsular conjuntos de dados que trafegam em rede dentro de outro conjunto de dados, de forma que a rota que os primeiros iam tomar seja conduzida para um lugar ou de uma maneira que sem o encapsulamento eles não poderiam fazer.

Existem vários motivos pelos quais se pode querer implementar um túnel:

- Proteger dados através de uma conexão criptografada não suportada localmente;
- Realizar uma conexão cujo protocolo seria bloqueado não fosse o uso do túnel;
- Conectar-se a um destino bloqueado para conexão direta;
- Conectar-se a uma máquina de rede interna como se fosse de dentro para fora;
- Mascaramento de IP.

Existem diversos aplicativos que nos permitem abrir túneis manualmente. Como o tunelamento pode possuir diferentes formas e funções, os aplicativos naturalmente funcionando de maneiras e sob condições diferentes.

Alguns deles foram projetados especificamente para tunelar conexões, enquanto outros podem ter mais de uma função ou mesmo ser um canivete suíço do TCP/IP.

Os aplicativos que podemos utilizar aqui são:

- Netcat (canivete suíço TCP/IP);
- OpenSSH (shell remoto/túnel criptográfico);
- Httptunnel (túnel http para atravessar firewalls);
- Corkscrew (tunela SSH em http para atravessar firewalls).

7.8. Prática dirigida

7.8.1. Tunelando com o Netcat

Abra três terminais.

A idéia é que um primeiro terminal vai escutar em uma porta de forma regular, um segundo vai abrir um túnel de uma porta arbitrária até a porta em que o servidor do primeiro terminal estiver escutando e o terceiro terminal vai se conectar, também de maneira regular, à porta arbitrária do tunel que levará essa conexão até a sua saída no serviço do primeiro terminal.

- T1 (servidor):



```
$ nc -l -vv 1026 | /bin/bash
```

- T2 (túnel) :



```
$ nc -l -vv 1025 | nc localhost 1026
```

- T3 (cliente):



```
$ nc localhost 1025
```

7.9. Anonymizer

Os programas de anonymizer funcionam basicamente para ocultar seus dados enquanto navega na internet.

Normalmente a aplicação utilizada para isso é um proxy, que após configurado, permite que seu IP seja mascarado, fornecendo o dele como IP real.

Com isso, é possível proteger o conteúdo de e-mails, textos de softwares de mensagens instantâneas, IRC e outros aplicativos que usam o protocolo TCP.

Uma boa ferramenta para utilizarmos mantendo nossos dados de navegação protegidos, é o TOR – The Onion Router.

O programa foi desenvolvido pelo Laboratório Central da Marinha para Segurança de Computadores, com a ajuda da Darpa (www.darpa.mil), a agência criada no auge da guerra fria com o objetivo de transformar os Estados Unidos em uma superpotência tecnológica. Para quem não se lembra, foi a Darpa (na época sem o D) quem coordenou os estudos para a construção de uma rede descentralizada de computadores, capaz de resistir a qualquer ataque localizado. Foi assim que nasceu a Arpanet, o embrião do que hoje chamamos internet.

O Tor andava meio esquecido, até que a Electronic Frontier Foundation, uma entidade civil que se destaca pelo vigor com que combate nos tribunais os abusos governamentais contra os direitos individuais, decidiu apoiar politicamente o projeto e contribuir financeiramente para que ele cresça, fique forte e consiga deixar cada vez mais gente invisível.

Outro programa, que trabalha junto com o TOR, é o privoxy, que evita o envio de qualquer dado enviado pelo navegado alcance a intranet, bloqueando-os no caminho. Isso evita que através desses dados, qualquer informação do internauta seja capturada, e sua localização descoberta.

TOR – The Onion Router

- <http://www.torproject.org/>

Privoxy

- <http://www.privoxy.org>

7.10. Prática dirigida

7.10.1. Navegando anonimamente

Acesse o site www.showmyip.com e veja seu endereço IP e o local de onde está acessando.

Instale o anon-proxy:



```
#aptitude install anon-proxy
```

Entre no navegador e configure o proxy para localhost na port 4001 (porta padrão do anon-proxy)

Acesse o mesmo site inicial e veja se o IP está diferente, assim como o local de onde está acessando.

7.11. Contramedidas

Manter regras de firewall bem configuradas, evitando que determinados tipos de varredura possam ser realizadas.

Não permitir que usuários na rede tenham acesso às configurações do navegador para configurar proxys.

Manter IDS's instalados e bem configurados, observando sempre seus logs e relatórios.